PEMILWA KMTEDI 2026 / DOKUMEN OPERASIONAL

PANDUAN UPDATE WEBSITE

Diperbarui 26 Oktober 2026 / kmtedi-pemilwa.vercel.app

Panduan ini berisi aturan yang wajib diikuti setiap kali website Pemilwa KMTEDI diubah, dideploy, atau kunci rahasianya diganti.

01 PRINSIP DASAR

Setiap update dikerjakan di branch terpisah dan baru masuk `main` setelah tes lulus serta situs sudah dicek.

- Buat branch baru untuk setiap perubahan, jangan langsung di `main`.
- Repo GitHub ini **publik**. Password, key, token, dan PIN tidak boleh ada di kode, dokumen, atau pesan commit.
- Semua kunci rahasia hanya disimpan di Environment Variables Vercel atau di Supabase.
- Detail teknis arsitektur ada di `AGENT_BRIEF.md` di root repo.

02 MENGUBAH TAMPILAN

Berlaku untuk `index.html`, `admin.html`, `app.js`, `admin.js`, `motifs.css`, dan `branding.css`.

- **Tanpa script inline.** Dilarang menulis `<script>...</script>` atau `onclick="..."` di HTML. Logika masuk ke `app.js` atau `admin.js`, tombol memakai atribut `data-action`. Jika dilanggar, browser memblokirnya karena aturan keamanan (CSP).
- **Escape data database.** Teks atau gambar dari database yang masuk ke halaman wajib lewat `escapeHtml()`, `richText()`, atau `safeImage()`.
- **File publik baru** (gambar, CSS, JS) wajib ditambahkan ke `PUBLIC_FILES` atau `PUBLIC_DIRS` di `build.js`. Jika tidak, file itu 404 di Vercel.
- **Domain luar baru** (font, CDN, host gambar) wajib ditambahkan ke `Content-Security-Policy` di `vercel.json`.
- **Aturan gaya:** tanpa emoji, tanpa tanda pisah panjang, popup memakai `showNotice` (bukan `alert` bawaan browser), teks di latar gelap memakai warna terang.

03 MENGUBAH API

Berlaku untuk file di folder `api/` dan `lib/server.js`.

- Ambil env dengan `requireEnv('NAMA')`, tanpa nilai cadangan seperti `|| 'xxx'`. Jika env kosong, API harus berhenti, bukan memakai nilai bawaan.
- Endpoint baru dibungkus `handler()`, memvalidasi semua input, dan memakai `rateLimit()`.
- Error dari database dikirim lewat `dbFailure()` agar pesan internal tidak bocor ke pengguna.

- Env baru wajib ditambahkan ke Vercel dan ke `.env.example` (tanpa nilai asli):

```
npx vercel env add NAMA_ENV production
```

04 MENGUBAH DATABASE

Perubahan database selalu lewat file migrasi baru, diuji lokal dulu, lalu dijalankan di SQL Editor Supabase.

- **Jangan mengedit migrasi lama** yang sudah pernah dijalankan. Buat file baru di `supabase/migrations/` dengan tanggal lebih baru, misalnya `20261101000000_nama_perubahan.sql`.
- **Fungsi baru hanya untuk server.** Setiap fungsi baru wajib ditutup dari publik:

```
revoke all on function public.nama_fungsi(text) from public, anon, authenticated;
grant execute on function public.nama_fungsi(text) to service_role;
```

- **Jangan pernah** `grant ... to anon`, kecuali memang data publik seperti hasil yang sudah dipublikasikan.
- **Gagal yang menambah hitungan** (misalnya jumlah percobaan OTP) dikembalikan sebagai `{ok:false}`, bukan `raise exception`. Raise membatalkan penambahan hitungannya dan membuka celah tebak-tebakan.
- **Uji dulu** sebelum dijalankan di Supabase:

```
npm run test:db
```

> Jika migrasi menghapus atau mengganti nama fungsi yang dipakai situs live, **deploy segera** setelah migrasi dijalankan.

05 URUTAN RILIS SETIAP UPDATE

Ikuti lima langkah ini berurutan, jangan ada yang dilompati.

1. Jalankan semua tes, dan pastikan semuanya lulus:

   ```
   npm test && npm run test:db
   ```

2. Jika ada migrasi baru, jalankan file itu di **SQL Editor** Supabase.
3. Deploy ke production:

   ```
   npx vercel --prod
   ```

4. Cek cepat di situs live: halaman utama terbuka, login `/admin` berhasil, dan jika perubahan menyentuh alur pemilih, coba kirim OTP ke email sendiri.
5. Merge ke `main` lalu push ke GitHub:

   ```
   git switch main && git merge --ff-only NAMA-BRANCH && git push origin main
   ```

06 MENGGANTI KUNCI DAN PASSWORD

Ganti kunci segera jika pernah tersebar, dan selalu deploy ulang setelah mengubah env di Vercel.

YANG DIGANTI	CARANYA	EFEKNYA
PIN admin	Jalankan `select private.set_admin_pin('PIN-BARU');` di SQL Editor (minimal 12 karakter)	Semua admin otomatis logout
App Password Gmail	Buat baru di myaccount.google.com/apppasswords, hapus yang lama, lalu `npx vercel env rm SMTP_PASS production` dan `npx vercel env add SMTP_PASS production`, lalu deploy	Pengiriman OTP memakai password baru
Service role key Supabase	Buat ulang di Project Settings, API Keys, lalu ganti `SUPABASE_SERVICE_ROLE_KEY` di Vercel dan deploy	API mati sampai env diperbarui
`ADMIN_SESSION_SECRET`	Isi nilai acak baru di Vercel, lalu deploy	Semua admin logout

Nilai acak untuk `ADMIN_SESSION_SECRET` bisa langsung dibuat dan dikirim ke Vercel tanpa ditampilkan:

```
node -e "process.stdout.write(require('crypto').randomBytes(48).toString('base64url'))" \
  | npx vercel env add ADMIN_SESSION_SECRET production
```

07 SELAMA BILIK SUARA DIBUKA

Selama bilik terbuka, sistem dibekukan: tidak ada deploy, migrasi, atau reset.

- **Jangan deploy atau menjalankan migrasi.** Tunggu sampai bilik ditutup.
- **Jangan reset kotak suara.** Sistem sudah menolak reset selama bilik terbuka.
- Rekap per calon di panel admin **sengaja disembunyikan** selama bilik terbuka. Itu fitur kerahasiaan suara, bukan error.
- Pantau error di Vercel (Project, lalu Logs).
- Pantau kuota Gmail: akun Gmail biasa dibatasi sekitar 500 email per hari. Setiap email dibatasi maksimal 6 kode OTP per jam.

08 SETELAH PEMILIHAN

Hasil baru dibuka ke publik setelah bilik ditutup dan rekap dicek panitia.

1. Tutup bilik suara dari panel admin, lalu lihat rekap per calon.
2. Klik **Buka Hasil ke Publik** jika hasil sudah siap diumumkan.
3. Reset kotak suara hanya jika datanya sudah tidak diperlukan. Reset menghapus semua suara dan daftar hadir secara permanen, dan wajib mengetik `RESET` sebagai konfirmasi.